OWASP Top 10 Evidence - FDS

SENG 34213 section 8.1 A01-A10 control-by-control review. Distinguishes passing unit/E2E security assertions from broader service/deployment controls.

DOCUMENT STATUS: PROVISIONAL REVIEW; UNRESOLVED FINDINGS AND GAPS

1 Scope and evidence snapshot

Item	Detail
Reviewed CI	Backend https://github.com/forever-hotel/front-desk/actions/runs/40057114169; Frontend https://github.com/forever-hotel/front-desk/actions/runs/40057114175
Tested revision	develop | 503465b7eb2c29b56cc2ec0d329d91d6b40853d4 | 2026-10-24 UTC
System boundary	FDS backend/frontend only. Central auth, API gateway, live WKMS/FOSS, TLS and cloud controls require separate evidence.
Guideline baseline	Section 8.1 requires A01-A10 evidence, including bcrypt>=12, unauthorized 403, CI dependencies, logging and SSRF allowlist.

2 OWASP checklist

A01 Broken Access Control

Status	Evidence / findings
PARTIALLY EVIDENCED	JWT, RBAC read/write roles and 401/403 E2E tests available. Not an audited guarantee for every endpoint.
Source	backend/test/bookings-rbac.e2e-spec.ts; backend/test/check-in-rbac.e2e-spec.ts; backend/test/rooms-rbac.e2e-spec.ts
Follow-up	Produce endpoint/role access matrix; negative tests for every protected endpoint.

A02 Cryptographic Failures

Status	Evidence / findings
NOT FULLY VERIFIED	JWT signature and issuer tests exist; password hashing with bcrypt cost >=12 and production TLS/hashed refresh tokens are central-auth/deployment responsibilities, not established by FDS CI.
Source	backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/src/config/env.validation.spec.ts
Follow-up	Obtain central auth evidence for bcrypt >=12, token handling and actual staging HTTPS/TLS.

A03 Injection

Status	Evidence / findings
PARTIALLY EVIDENCED	PostgreSQL repository uses parameter placeholders; DTO and text sanitation tests present. Exhaustive injection fuzzing not shown.
Source	backend/src/reservations/repositories/postgres-booking.repository.ts; backend/src/security/sanitization/sanitize-plain-text.spec.ts
Follow-up	Perform targeted SQL/NoSQL injection and input validation tests per route.

A04 Insecure Design

Status	Evidence / findings
NOT VERIFIED	Transaction/audit protections have code and tests; signed threat model/design security review not verified from CI.
Source	backend/test/database/postgres-checkout.repository.integration-spec.ts; backend/test/database/audit-append-only.integration-spec.ts
Follow-up	Link reviewed SDS threat model and architecture/security review decisions.

A05 Security Misconfiguration

Status	Evidence / findings
PARTIALLY EVIDENCED	Staging/production env validation checks JWT secrets, wildcard origins and DB_SYNCHRONIZE; deployed error handling / default credentials not verified.
Source	backend/src/config/env.validation.spec.ts; backend/src/config/env.validation.ts
Follow-up	Run hardened staging configuration test and production error disclosure review.

A06 Vulnerable Components

Status	Evidence / findings
OPEN FINDING	Backend high-level dependency audit passed (0 findings). Frontend production-only audit passed (0). Nonblocking full frontend audit found 1 HIGH in dev-dependency undici 8.0.0-8.12.1.
Source	Backend CI 40057114169; Frontend CI 40057114175
Follow-up	Remediate/update undici as feasible, rerun full audit, document accepted residual risk before sign-off.

A07 Authentication Failures

Status	Evidence / findings
PARTIALLY EVIDENCED	JWT invalid/expired/issuer/signature denial tested; centralized login rate limiting/account lockout not evidenced in FDS.
Source	backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/test/realtime.e2e-spec.ts
Follow-up	Obtain central authentication service lockout/session rotation tests.

A08 Software and Data Integrity Failures

Status	Evidence / findings
PARTIALLY EVIDENCED	package-lock.json present; npm ci used in CI; append-only audit DB trigger tested. Full artifact signing / supply chain provenance not verified.
Source	backend/package-lock.json; frontend/package-lock.json; .github/workflows/backend-ci.yml
Follow-up	Review dependency provenance/build integrity and migration/change control.

A09 Security Logging and Monitoring Failures

Status	Evidence / findings
PARTIALLY EVIDENCED	Audit logging and PII/secret redaction tests exist; comprehensive auth-failure/data access logging and monitoring not proven.
Source	backend/src/security/redaction/log-redactor.spec.ts; backend/test/database/audit-append-only.integration-spec.ts
Follow-up	Verify staged auth/authorization failure logging with redacted records and alerting.

A10 Server-Side Request Forgery

Status	Evidence / findings
NOT VERIFIED	WKMS HTTP integration client exists; no dedicated SSRF/URL allow-list test was located in reviewed evidence.
Source	backend/src/integrations/wkms/wkms-http.client.spec.ts
Follow-up	Verify fixed trusted service endpoint and outbound allowlist; test rejected untrusted URLs.

3 Dependency audit finding and remediation

Backend CI completed npm audit --audit-level=high reporting 0 vulnerabilities. Frontend CI completed npm audit --omit=dev --audit-level=high reporting 0 production vulnerabilities. However, a separate nonblocking full frontend audit ended in exit code 1 and reported 1 HIGH severity vulnerability in undici 8.0.0-8.12.1 (dev dependency). Therefore, do NOT record an unqualified full-tree "0 vulnerabilities" conclusion.

- Advisory: https://github.com/advisories/GHSA-4qv8-2p9j-2685
- Advisory: https://github.com/advisories/GHSA-f72v-6w45-q472
- Advisory: https://github.com/advisories/GHSA-xjj6-f33q-929c

The finding is observed in the historical 24 October 2026 frontend run. Its remediation status on later commits has not been verified here.

4 Security sign-off checklist

- Map every API route to required roles and prove unauthorized/forbidden status codes.
- Verify bcrypt hashing strength and session protections in the central authentication service.
- Test live staging HTTPS, CORS, stack-trace handling and secret management.
- Rerun npm audit (both production-only and full dependency trees), and retain new results.
- Complete threat model review, SSRF controls and security logging/monitoring evidence.
- Reclassify each A01-A10 item only when reviewed evidence is attached.

Completion status: NOT signed off as fully OWASP compliant. This PDF documents verified controls and remaining work.